Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Introducción a la Seguridad en el Software y DevSecOps

Ing. Roxana Quiroga Sollinger



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

1.1 El software funciona, pero ¿es seguro?

1.2 ¿Por qué falla el software?

1.3 El costo real de la inseguridad

1.4 El SDLC tradicional y la seguridad tardía

1.5 De Agile a DevOps

1.6 DevSecOps: integrar seguridad

1.7 CAMS: Culture y Automation

1.8 CAMS: Mesurement y Sharing

1.9 La seguridad como proceso continuo



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

El software funciona, pero ¿es seguro?



1.1 El software funciona, pero ¿es seguro?

- Introducción ¿cómo nace el software? (ISO 29148:2018)
- ¿Qué significa que un software sea seguro?
- Seguridad como atributo de calidad del software
- Los atributos de la seguridad del software
- Seguridad del software vs. ciberseguridad
- Introducción al concepto de Software Security



1.1 El software funciona, pero ¿es seguro?

Introducción ¿cómo nace el software? (ISO 29148:2018)

Análisis de Negocio o Visión

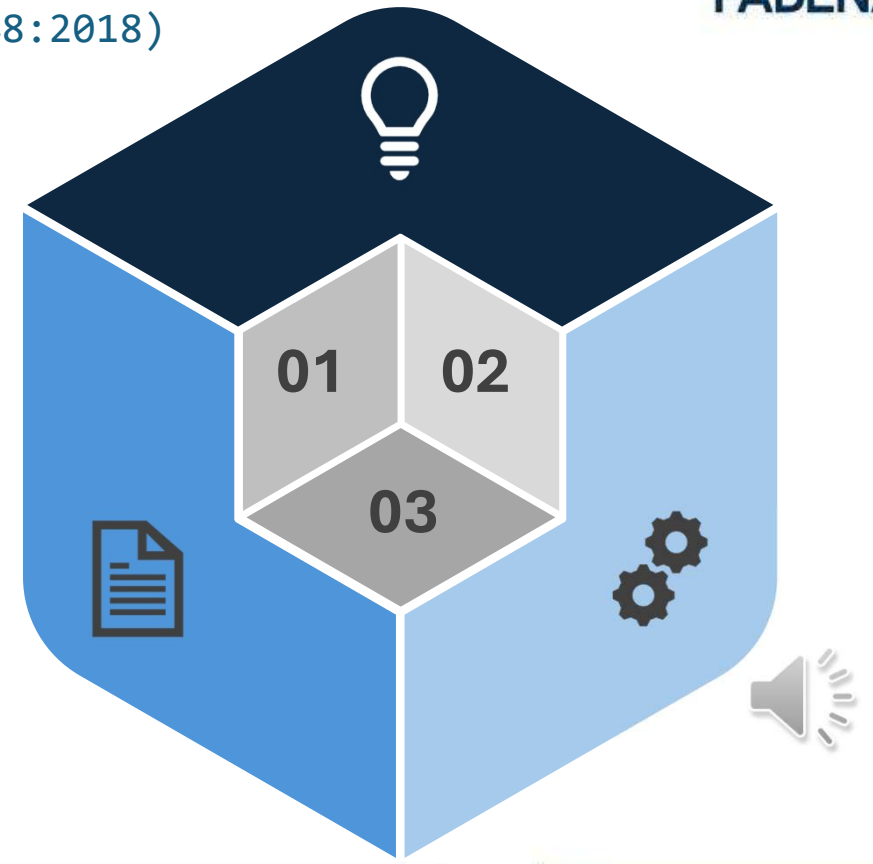
Identifica una brecha en la organización, un problema operacional por resolver o una oportunidad de mercado. Define el "por qué" y los objetivos del negocio antes de plantear cualquier solución tecnológica.

Definición de las partes interesadas

Recopila las expectativas, limitaciones y contexto de uso de las personas que interactuarán directa o indirectamente con la solución (usuarios, administradores, reguladores). Formaliza cómo se comportará el sistema en su entorno real a través de documentos operativos

Especificación Formal

Transforma las necesidades del usuario en especificaciones técnicas formales, cuantificables y sin ambigüedades. Culmina en la Especificación de Requisitos de Software (SRS), la línea base sobre la cual los desarrolladores diseñarán la arquitectura y escribirán el código.



1.1 El software funciona, pero ¿es seguro?

Introducción ¿cómo nace el software? (ISO 29148:2018)

Trazabilidad

Ningún requisito de software nace sin documentación respaldatoria. Cada elemento en la SRS debe estar vinculado directamente a una necesidad justificada de un interesado o del negocio.



Proceso iterativo

El origen del software no es una línea recta. ISO 29148 contempla ciclos de retroalimentación donde la validación constante asegura que lo que se especifica es exactamente lo que el usuario necesita antes de invertir recursos en desarrollo.

Criterios de calidad

Para considerar que un requisito ha nacido correctamente, debe cumplir con características esenciales: ser necesario, realizable, no ambiguo, verificable y consistente.

1.1 El software funciona, pero ¿es seguro?

¿Qué significa que un software sea seguro?

> *La seguridad del software es la disciplina de diseñar y desarrollar software de manera que continúe funcionando correctamente incluso cuando es objeto de ataques maliciosos.*

1.1 El software funciona, pero ¿es seguro?

¿Qué es la seguridad en el software?

> *La seguridad del software consiste en identificar, comprender y gestionar los riesgos de seguridad que pueden surgir durante el desarrollo y funcionamiento del software. Para ello, se fundamenta en buenas prácticas de ingeniería de software e incorpora la seguridad desde las etapas iniciales del ciclo de vida del desarrollo. Esto implica conocer las vulnerabilidades más comunes, comprender las limitaciones y riesgos asociados a los lenguajes de programación, diseñar aplicaciones seguras desde su arquitectura y evaluar continuamente todos los artefactos del software mediante análisis de riesgos y pruebas de seguridad.*

1.1 El software funciona, pero ¿es seguro?

Seguridad como atributo de calidad del software

la seguridad del software puede analizarse como un atributo de calidad, al mismo nivel que el rendimiento, la mantenibilidad, la disponibilidad o la usabilidad.

La ISO 25010:2023 define a la seguridad del software como un atributo de calidad.

La seguridad en la ISO 25010:2023 se encuentra definida como el grado en que un producto o sistema protege la información y los datos de manera que las personas u otros productos o sistemas tengan el grado de acceso apropiado de acuerdo con sus tipos y niveles de autorización.



1.1 El software funciona, pero ¿es seguro?

Seguridad del software como un atributo de calidad

ASPECTOS DE LA SEGURIDAD



1.1 El software funciona, pero ¿es seguro?

Seguridad del software como un atributo de calidad



Adecuación funcional

Grado en que un producto o sistema proporciona funciones que satisfacen las necesidades explícitas e implícitas cuando se utiliza bajo condiciones especificadas.

Eficiencia del desempeño

Desempeño relativo a la cantidad de recursos utilizados bajo condiciones establecidas.

Compatibilidad

Grado en que un producto, sistema o componente puede intercambiar información con otros productos, sistemas o componentes y desempeñar sus funciones mientras comparte un mismo entorno de hardware o software.

Usabilidad

Grado en que un producto o sistema puede ser utilizado por usuarios específicos para alcanzar objetivos específicos con efectividad, eficiencia y satisfacción en un contexto de uso determinado.

Confiabilidad

Grado en que un sistema, producto o componente desempeña las funciones especificadas bajo condiciones determinadas durante un período de tiempo determinado.

Seguridad

Grado en que un producto o sistema protege la información y los datos de manera que las personas u otros sistemas tengan el grado de acceso apropiado de acuerdo con sus tipos y niveles de autorización.

Mantenibilidad

Grado de efectividad y eficiencia con que un producto o sistema puede ser modificado por los responsables de su mantenimiento.

Portabilidad

Grado de efectividad y eficiencia con que un sistema, producto o componente puede transferirse de un entorno de hardware, software, operación o utilización a otro.

1.1 El software funciona, pero ¿es seguro?

Los atributos de la seguridad del software

Los cinco pilares de la seguridad de la información son la confidencialidad, la integridad, la disponibilidad, la autenticidad y el no repudio definidos también como atributos de la seguridad del software según ISO 25010, el cúal agrega en 2023:

Resistencia



1.1 El software funciona, pero ¿es seguro?

Los atributos de la seguridad del software

Confidencialidad



Sensibilidad

Calidad de la información que podría causar daño o perjuicio si se divulga.

Discreción

Decisión mediante la cual un operador puede influir o controlar la divulgación para minimizar el daño o perjuicio.

Criticidad

Cuanto mayor sea el nivel de criticidad, mayor será la necesidad de mantener la confidencialidad de la información.

Ocultación

Acto de esconder o impedir la revelación. En general se considera que la ocultación es un medio de encubrimiento, ofuscación o distracción.

Secreto

Acto de mantener algo en secreto o impedir la divulgación de información.

Privacidad

Mantener confidencial la información que permite identificar a una persona o que podría causar daño si se revelara

Reclusión

Implica guardar algo en un lugar apartado, probablemente con estrictos controles de acceso.

Aislamiento

Acto de mantener algo separado de los demás.

1.1 El software funciona, pero ¿es seguro?

Los atributos de la seguridad del software

Integridad

PERSPECTIVAS DE LA INTEGRIDAD



1.1 El software funciona, pero ¿es seguro?

Introducción al concepto de Software Security

Integridad



Exactitud

Ser correcto y preciso

Veracidad

Ser un fiel reflejo de la realidad

Validez

Ser fáctica y lógicamente sólido

Rendición de Cuentas

Ser responsable u obligado por las acciones y los resultados

Responsa-bilidad

Estar a cargo o tener control sobre algo o alguien

Completitud

Tener todos los componentes o partes necesarios

Integrabi-lidad

Ser complete en su alcance; la inclusion total de todos los elementos necesarios

1.1 El software funciona, pero ¿es seguro?

Introducción al concepto de Software Security

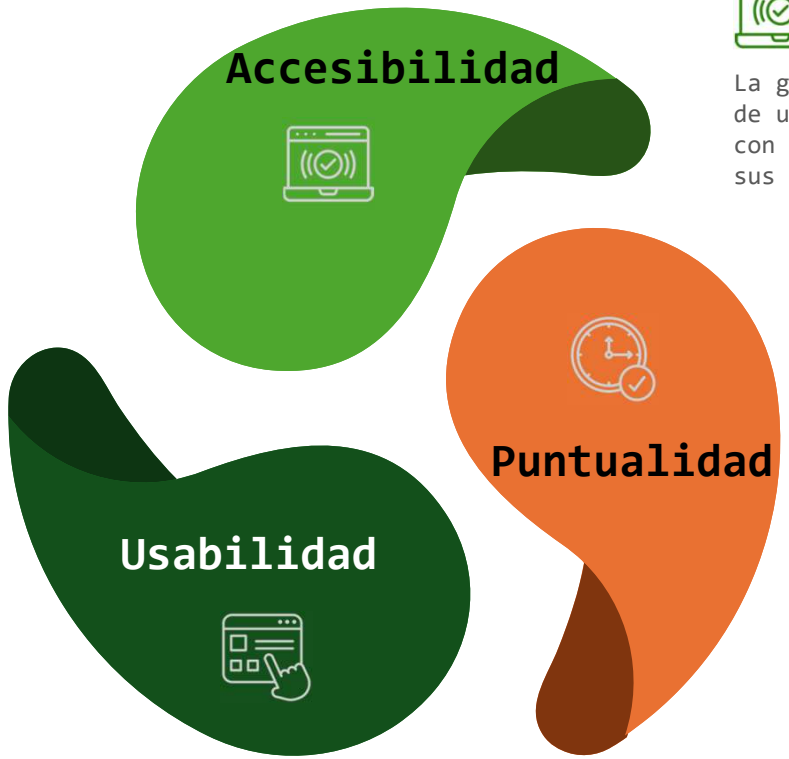
Disponibilidad



1.1 El software funciona, pero ¿es seguro?

Introducción al concepto de Software Security

Disponibilidad



Accesibilidad

La garantía de que la mayor cantidad de usuarios posible pueda interactuar con un recurso, independientemente de sus capacidades o limitaciones.

Usabilidad

El estado de ser fácil de usar o aprender, o de poder ser comprendido y controlado por un usuario.

Puntualidad

Ser rápido, puntual, dentro de un plazo razonable, o proporcionando una respuesta de baja latencia.

1.1 El software funciona, pero ¿es seguro?

Introducción al concepto de Software Security

Autenticidad y No Repudio



Autenticidad

Concepto de seguridad de que los datos son auténticos o genuinos y se origina en su supuesta fuente



No Repudio

Garantiza que el sujeto de una actividad o quien causó un evento no pueda negar que este ocurrió. El no repudio impide que un sujeto alegue no haber enviado un mensaje, no haber realizado una acción o no haber sido la causa de un evento.

1.1 El software funciona, pero ¿es seguro?

Seguridad del software vs. ciberseguridad



SEGURIDAD DEL SOFTWARE

La seguridad del software es la disciplina de diseñar y desarrollar software de manera que continúe funcionando correctamente incluso cuando es objeto de ataques maliciosos.

VS



CIBERSEGURIDAD

Prevención de daños, protección y restauración de ordenadores, sistemas de comunicaciones electrónicas, servicios de comunicaciones electrónicas, comunicaciones por cable y comunicaciones electrónicas, incluida la información contenida en ellos, para garantizar su disponibilidad, integridad, autenticación, confidencialidad y no repudio.

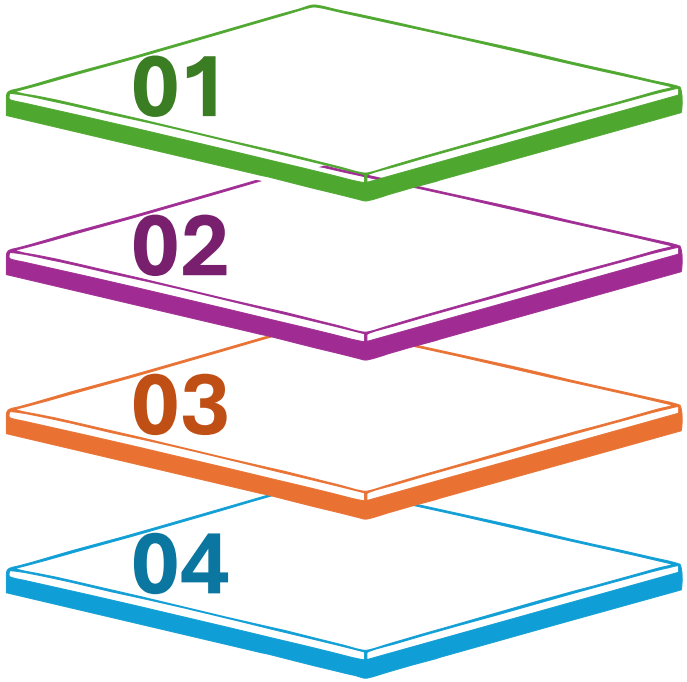
1.1 El software funciona, pero ¿es seguro?

Seguridad de Software versus Ciberseguridad

Aspecto	Seguridad del Software	Ciberseguridad
Definición	La seguridad del software es la disciplina de diseñar y desarrollar software de manera que continúe funcionando correctamente incluso cuando es objeto de ataques maliciosos.	Prevención de daños, protección y restauración de computadoras, sistemas de comunicaciones electrónicas, servicios de comunicaciones electrónicas, comunicaciones por cable y comunicaciones electrónicas.
Alcance	Construir aplicaciones seguras desde el diseño considerando a la seguridad como un atributo de calidad del software, incluyendo la cadena de suministro de software.	Infraestructura, redes, usuarios y operación incluyendo la información contenida en ellos, con el fin de garantizar su disponibilidad, integridad, autenticidad, confidencialidad (triada CIA) y no repudio.
Enfoque	Preventivo con el objeto eliminar vulnerabilidades antes de que el software llegue a producción.	Preventivo, de detección y correctivo.
Activo protegido	La aplicación en su total y su código.	Toda la organización y sus activos digitales.
Normas de referencia	OWASP SAMM, BSIMM, Secure SDLC, DevOpsSec, CERT Secure Coding.	NIST Cybersecurity Framework, ISO/IEC 27001, CIS Controls.

1.1 El software funciona, pero ¿es seguro?

Introducción al concepto de Software Security



Diseño
Etapa en la que se define cómo se construirá el software para satisfacer sus requisitos.

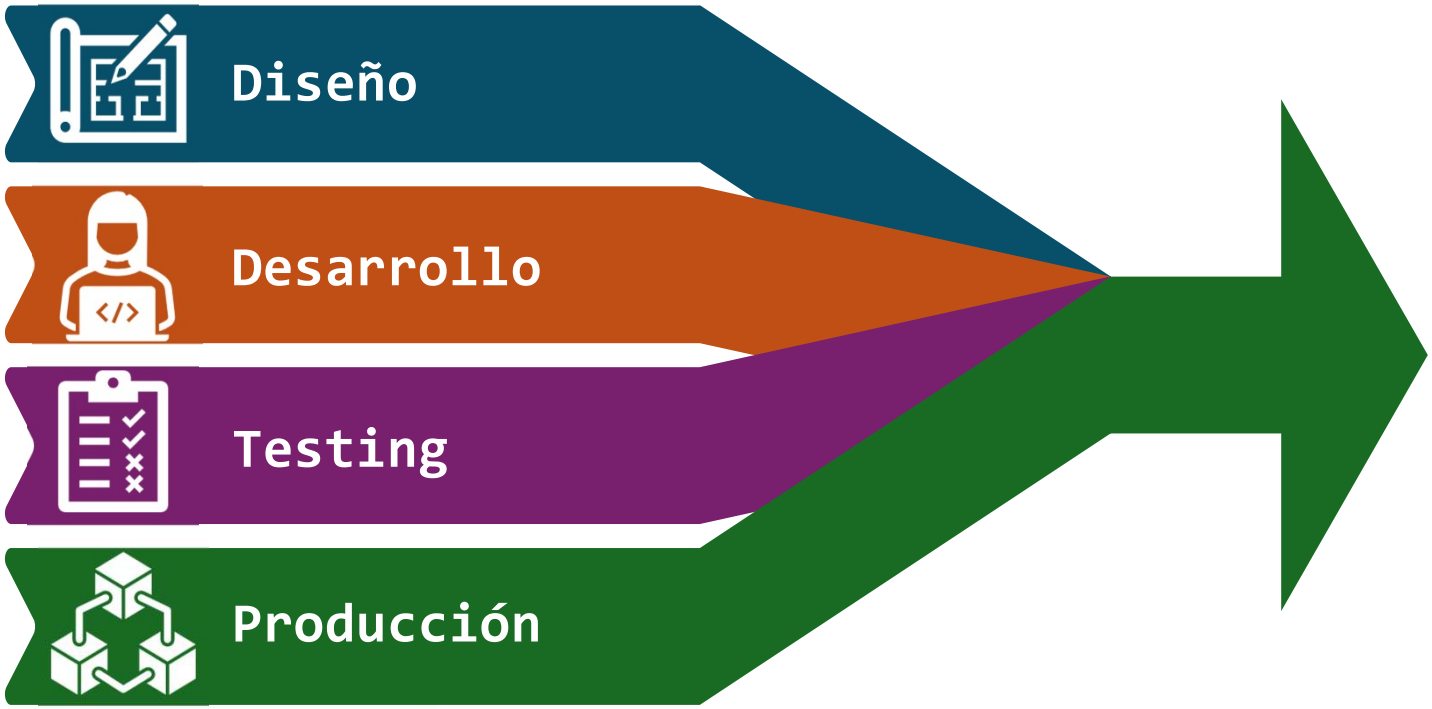
Desarrollo
Proceso mediante el cual las decisiones de diseño se transforman en software.

Testing
Proceso en la cual es evalúan los requisitos funcionales y no funcionales.

Producción
Etapa final del proceso donde se implementa el software en su entorno productivo.

1.1 El software funciona, pero ¿es seguro?

Introducción al concepto de Software Security



La seguridad del software es la disciplina orientada a construir software que pueda resistir ataques y mantener sus propiedades de seguridad bajo condiciones adversas habiendo sido acompañado en todas las etapas del desarrollo